

CEHv13 Module 2 – Footprinting and Reconnaissance

NOTES BY VIVEK GOSWAMI

Footprinting is the process of collecting information about the target system, application, network, and organisation to identify potential attack vectors and reduce the attack surface scope

Objectives of Footprinting:

- Collect publicly available information about the target.
- Map the target's digital presence (domains, subdomains, IP ranges).
- Identify technologies used by the target (servers, frameworks, apps).
- Gather employee or organisational details for social engineering.
- Prepare for further penetration testing phases.
- Perform Footprinting using AI

Footprinting Methodologies

Passive Footprinting

Information gathering without direct interaction with target systems, minimising detection risk.

Characteristics:

- No direct target contact: Information gathered from third-party sources
- Stealth approach: Minimal detection risk and forensic evidence
- Publicly available data: Relies on open source intelligence (OSINT)
- Legal compliance: Generally permissible as uses public information

Techniques of Footprinting:

- Search Engines – Google Dorks, Bing, Shodan, Censys, Zoomeye, ONYPHE.
- WHOIS Lookup – Registrar details (the company that sold the domain), Registrant information, Name servers, Administrative and Technical contacts.
- DNS Enumeration – NSLookup, dig, dnsenum, dnsrecon, Fierce, Nmap Dns script, Amass, sub-finder, MassDns, DNSX .

- Social Media Profiling – LinkedIn, Twitter, Facebook, Instagram, Matrimonial websites, Google Lens
- Email Harvesting – theHarvester, [Hunter.io](https://hunter.io), Recon-ng, metagoofil(extract metadata from public documents and catch emails), infoga .
- Website Footprinting – Wappalyzer, WhatWeb, BuiltWith, Nmap with HTTP NSE script, nikto, Dirsearch, .
- Network Recon – Traceroute, Ping, Nmap, Masscan, Zmap, Rustscan, Wireshark, angryip scanner.
- Metadata Extraction – ExifTool, FOCA, ExifRead, mat2, pdftinfo, ffprobe
- Public Data Sources – Job postings, press releases, Google Alerts.

Here is a website for Dns info - <https://viewdns.info/>

Active Footprinting

Direct interaction with target systems to gather detailed technical information.

Characteristics:

- Direct system interaction: Scanning, probing, and service enumeration
- Higher information quality: Detailed technical specifications
- Detection risk: May trigger security alerts and logging
- Legal considerations: Requires explicit authorisation

Key Techniques:

- Network scanning: Port scans, service detection, OS fingerprinting
- DNS enumeration: Zone transfers, subdomain brute forcing
- Social engineering: Phone calls, emails, physical reconnaissance
- Website interaction: Technology fingerprinting, directory enumeration

=====

SEARCH ENGINES (OSINT USE)

=====

Google Dorks:

site:example.com filetype:pdf "confidential"

intitle:"index of" site:example.com

Bing:

site:example.com

Shodan:

shodan search "apache" "port:80"

Censys:

censys search 'services.service_name: "http" AND ip:10.0.0.0/8'

Zoomeye:

zoomeye search app:"nginx"

ONYPHE:

onyphe ip 8.8.8.8

=====
WHOIS LOOKUP
=====

whois example.com

Information returned:

- Registrar
- Registrant info (if not privacy-protected)
- Name servers
- Creation/expiration dates
- Admin/tech contacts

=====
DNS ENUMERATION
=====

NSLookup:

nslookup example.com

Dig:

```
dig example.com ANY
dig mx example.com
```

dnsenum:

```
dnsenum example.com
```

dnsrecon:

```
dnsrecon -d example.com -a
```

Fierce:

```
fierce --domain example.com
```

Nmap DNS Scripts:

```
nmap --script dns-brute -sn example.com
nmap --script dns-zone-transfer -p 53 example.com
```

Amass:

```
amass enum -d example.com
```

Subfinder:

```
subfinder -d example.com
```

MassDNS:

```
massdns -r resolvers.txt -t A -o S wordlist.txt
```

DNSX:

```
dnsx -d example.com
```

```
=====
SOCIAL MEDIA PROFILING (OSINT)
=====
```

LinkedIn – employee info, tech stack hints

Twitter – public posts/usernames

Facebook – public profiles only

Instagram – public posts
 Matrimonial sites – public info
 Google Lens – reverse image search

=====

EMAIL HARVESTING (LEGAL OSINT)

=====

theHarvester:

```
theHarvester -d example.com -b bing
theHarvester -d example.com -b all
```

Hunter.io API:

```
curl
"https://api.hunter.io/v2/domain-search?domain=example.com&api_key=KEY"
```

Recon-ng:

```
recon-ng
marketplace install recon/domains-contacts/hunter_io
modules load recon/domains-contacts/hunter_io
set source example.com
run
```

metagoofil:

```
metagoofil -d example.com -t pdf,docx -l 50 -o output/
```

Infoga:

```
python infoga.py --domain example.com --source all --verbose
```

=====

WEBSITE FOOTPRINTING

=====

Wappalyzer CLI:

```
wappalyzer https://example.com
```

WhatWeb:

```
whatweb https://example.com
```

BuiltWith API:

```
curl "https://api.builtwith.com/v21/api.json?KEY&LOOKUP=example.com"
```

Nmap (HTTP NSE):

```
nmap -p 80,443 --script http-enum,https-redirect example.com
```

Nikto:

```
nikto -h https://example.com
```

Dirsearch:

```
dirsearch -u https://example.com -e php,html
```

```
=====
NETWORK RECON
=====
```

Traceroute:

```
traceroute example.com
```

Ping:

```
ping example.com
```

Nmap:

```
nmap -sV example.com
```

Masscan:

```
masscan 10.0.0.0/24 -p80
```

Zmap:

```
zmap -p 80 10.0.0.0/8
```

Rustscan:

```
rustscan -a example.com --ulimit 5000
```

Wireshark (tshark):

```
tshark -i eth0
```

Angry IP Scanner:

GUI only

```
=====
METADATA EXTRACTION
=====
```

ExifTool:

```
exiftool file.jpg
```

FOCA:

(GUI) document metadata extraction

ExifRead:

```
exifread file.jpg
```

mat2:

```
mat2 file.pdf
```

pdftinfo:

```
pdftinfo file.pdf
```

ffprobe:

```
ffprobe video.mp4
```

```
=====
PUBLIC DATA SOURCES (OSINT)
=====
```

Job postings – tech stack, infra clues

Press releases – org changes, new systems

Google Alerts – notifications for new public data

Common Tools for Footprinting:

- - theHarvester – Email and domain information gathering from multiple public sources, including search engines, PGP key servers, and SHODAN.
- - Maltego – Relationship mapping and intelligence visualisation with extensive OSINT transforms.
- - Recon-ng – Web reconnaissance framework with modular, API-driven data collection.
- - Shodan – Search engine for discovering IoT devices and connected assets on the internet.
- - Censys – Internet-wide scanning engine used for asset discovery and vulnerability assessment.
- - FOCA – Tool for metadata analysis to extract hidden information from documents.
- - OSINT Framework – A collection of OSINT resources and tools to assist automated footprinting and reconnaissance.

These tools collectively help map digital presence, gather technical and organisational details, and support both passive and active footprinting techniques essential for effective penetration testing preparation.

Technology Stack Identification:

Web Technology Fingerprinting:

- - Server technologies: Identify web servers such as Apache, Nginx, IIS.
- - Programming languages: Detect languages in use like PHP, Python, Java, .NET.
- - Frameworks: Recognize web frameworks such as React, Angular, Django, Laravel.
- - Content management systems: Identify platforms like WordPress, Drupal, Joomla.

- - Analytics and tracking: Detect tools like Google Analytics and social media pixels.

Tools and Techniques:

- - Browser extensions: Wappalyzer, BuiltWith, and WhatRuns to fingerprint technologies.
- Command-line tools: whatweb and WebTechNOTice for detailed analysis.
- Response header analysis: Examine server headers and X-Powered-By headers to identify software versions.
- Source code analysis: Analyse JavaScript libraries and CSS frameworks referenced in the site's code.

Passive Vs Active Footprinting

Feature	Passive Footprinting	Active Footprinting
Target Interaction	None	Direct interaction
Detectability	Very low	High
Risk Level	Low	Higher
Data Depth	Basic / Public info	Detailed / Technical
Speed	Slower	Faster
Example Tools	WHOIS, Search Engines, Public Records	Nmap, Ping, Traceroute, DNS zone transfers
Stealth	High	Low
Suitability	When you don't want to tip off the target	When you need real data and don't care if logs start screaming

Email Pattern Analysis

Common email patterns for organisations

- ❖ firstname.lastname@company.com

- ❖ first.last@company.com
- ❖ f.lastname@company.com
- ❖ firstname@company.com
- ❖ [flastname@company.com](#)

DNS Footprinting and Enumeration

DNS Record Types and Intelligence Value:

A Records (IPv4 Addresses)

- Primary use: Maps domain names to IPv4 addresses
- Intelligence value: Reveals server infrastructure and hosting providers
- Security implications: Direct access points for targeted attacks

AAAA Records (IPv6 Addresses)

- Primary use: Maps domain names to IPv6 addresses
- Intelligence value: Modern infrastructure and dual-stack configurations
- Security implications: Often overlooked in security configurations

MX Records (Mail Servers)

- Primary use: Specifies mail servers for email delivery
- Intelligence value: Email infrastructure and third-party services
- Security implications: Email security posture and phishing targets

TTL (Time to Live)

- Primary use: Caching duration for DNS records
- Intelligence value: Infrastructure change frequency and practices
- Security implications: DNS cache poisoning and hijacking opportunities

CNAME Records (Aliases)

- Primary use: Domain name aliases and redirections
- Intelligence value: Service relationships and infrastructure mapping
- Security implications: Subdomain takeover vulnerabilities

TXT Records (Text Information)

- Primary use: Domain verification and policy specification
- Intelligence value: Third-party services, SPF, DKIM, DMARC policies
- Security implications: Email security posture and service enumeration

Zone Transfer Attacks

- DNS Zone Transfers allow secondary DNS servers to replicate the complete DNS zone data from primary servers.

- Misconfigured zone transfers can expose the entire DNS zone data to attackers.

To perform a DNS Zone Transfer attack, follow these steps:

1. Identify the target domain and its DNS servers.
2. Use a tool like dig or nslookup to query the DNS server for the zone transfer.
3. If the DNS server allows zone transfers, it will return the entire DNS zone file, which contains all the DNS records for the domain.
4. Analyse the zone file to identify potential vulnerabilities, such as subdomains that could be used for phishing attacks or other malicious activities.

Here's an example using `dig`:

```
...  
$ dig @dns-server.example.com axfr example.com  
...
```

This command queries the DNS server at `dns-server.example.com` for the zone transfer of the `example.com` domain. If the DNS server allows zone transfers, it will return the entire zone file.

Reconnaissance

Reconnaissance, on the other hand, is the process of actively probing the target system or network to gather additional information. This includes techniques such as port scanning, vulnerability scanning, and network mapping. The goal of reconnaissance is to identify potential vulnerabilities and weaknesses in the target system or network that can be exploited during the exploitation phase.

According to the Certified Ethical Hacker (CEH) v13 certification, the key differences between footprinting and reconnaissance are:

- Footprinting is passive, while reconnaissance is active.

- Footprinting focuses on gathering publicly available information, while reconnaissance involves direct interaction with the target system or network.
- Footprinting is typically performed before reconnaissance, as it provides a foundation for further investigation.

Common Tools for Footprinting and Reconnaissance

1. Nslookup : A command-line tool for querying DNS servers.

`nslookup example.com`

Usage: Replace `example.com` with the target domain.

2. Dig : A command-line tool for querying DNS servers.

`dig example.com`

Usage: Replace `example.com` with the target domain.

3. Whois : A command-line tool for querying WHOIS databases.

`whois example.com`

Usage: Replace `example.com` with the target domain.

4. Nmap : A command-line tool for network scanning and reconnaissance.

`nmap -sS example.com`

Usage: Replace `example.com` with the target domain.

5. TheHarvester : A command-line tool for gathering email addresses and subdomains.

`theharvester -d example.com -b google`

Usage: Replace `example.com` with the target domain.

6. Sublist3r : A command-line tool for discovering subdomains.

`sublist3r -d example.com`

Usage: Replace `example.com` with the target domain.

7. Shodan : A command-line tool for searching for internet-connected devices.

`shodan search example.com`

Usage: Replace `example.com` with the target domain.

8. Maltego : A graphical tool for visualizing relationships between entities.

`maltego example.com`

Usage: Replace `example.com` with the target domain.

9. Fierce: A command-line tool for DNS enumeration.

`fierce -dns example.com`

Usage: Replace `example.com` with the target domain.

10. DNSdumpster: A web-based tool for DNS enumeration.

dnsdumpster example.com

Usage: Replace `example.com` with the target domain.

Note: These tools may require installation and configuration before use.

Practical for Footprinting:

Lab 1: WHOIS Lookup

- Perform WHOIS lookup on a target domain to gather domain registration details.

Lab 2: DNS Enumeration

- Use nslookup or dig commands to extract DNS records and understand network infrastructure.

Lab 3: Email Harvesting

- Collect email addresses from public sources using the Harvester tool.

Lab 4: Search Engine Footprinting

- Use Google Dorks to find sensitive files, exposed directories, or other valuable information.

Defensive Countermeasures:

- - Limit public exposure of sensitive data.
- - Use privacy protection for WHOIS records to mask personal domain registration information.
- - Disable directory listing on web servers to prevent unauthorised access to file structures.
- - Train employees to avoid oversharing on social media and be aware of social engineering risks.
- - Monitor OSINT sources regularly for potential data leaks or sensitive information exposure.
- - Conduct periodic audits of the organisation's digital footprint to identify and mitigate vulnerabilities.

PERFORM FOOTPRINTING USING AI

1. Footprinting a Target using ShellGPT

To use ShellGPT for harvesting emails of a target organisation. To do so, run
sgpt --chat footprint --shell "Use theHarvester to gather email accounts associated with 'microsoft.com', limiting results to 200, and leveraging 'baidu' as a data source"

To perform footprinting through social networking sites using ShellGPT, to do so run
sgpt --chat footprint --shell "Use Sherlock to gather personal information about 'Sundar Pichai' and save the result in recon2.txt"

To perform DNS lookup using ShellGPT, run:
sgpt --chat footprint --shell "Install and use DNSRecon to perform DNS enumeration on the target domain www.certifiedhacker.com"

For tracerouting:
sgpt --chat footprint --shell "Perform network tracerouting to discover the routers on the path to a target host www.certifiedhacker.com"

To automate footprinting tasks:
sgpt --chat footprint --shell "Develop a Python script which will accept domain name microsoft.com as input and execute a series of website footprinting commands, including DNS lookups, WHOIS records retrieval, email enumeration, and more to gather information about the target domain"